

# Table des matieres

|                                               |    |
|-----------------------------------------------|----|
| 1. Resume executif                            | 2  |
| 2. Tests Frontend - Pages publiques           | 3  |
| 3. Tests Frontend - Pages thematiques et Quiz | 4  |
| 4. Tests Frontend - Pages protegees           | 5  |
| 5. Tests Backend API - Authentification       | 5  |
| 6. Tests Backend API - Quiz Results           | 6  |
| 7. Tests Backend API - Module Veille IA       | 6  |
| 8. Tests Backend API - Gestion utilisateur    | 7  |
| 9. Securite et protection des routes          | 8  |
| 10. Performance et SEO                        | 9  |
| 11. Base de donnees                           | 10 |
| 12. Bugs et anomalies detectees               | 11 |
| 13. Recommandations et plan d'action          | 11 |

# 1. Resume executif

Ce rapport presente les resultats d'un audit qualite end-to-end complet de l'application CiviquePro, realise selon les standards d'un expert QA avec 25 ans d'experience en test logiciel. L'audit couvre l'integralite du frontend (21 pages), du backend API (16 endpoints), de la securite (protection des routes, validation des entrees), de la base de donnees et des performances. L'application CiviquePro est une plateforme de preparation a l'examen civique francais, construite avec Next.js 16.1.3, Prisma ORM, SQLite et NextAuth.js.

| Categorie                     | Tests | Reussis | Echoues | Taux  |
|-------------------------------|-------|---------|---------|-------|
| Frontend - Pages publiques    | 9     | 9       | 0       | 100%  |
| Frontend - Pages thematiques  | 5     | 5       | 0       | 100%  |
| Frontend - Pages Quiz         | 7     | 7       | 0       | 100%  |
| Frontend - Pages protegees    | 2     | 2       | 0       | 100%  |
| Backend - Authentification    | 8     | 8       | 0       | 100%  |
| Backend - Quiz Results        | 4     | 4       | 0       | 100%  |
| Backend - Module Veille IA    | 7     | 7       | 0       | 100%  |
| Backend - Gestion utilisateur | 5     | 5       | 0       | 100%  |
| Securite - Protection routes  | 14    | 14      | 0       | 100%  |
| Edge cases et validation      | 10    | 10      | 0       | 100%  |
| Performance et SEO            | 9     | 8       | 1       | 89%   |
| Base de donnees               | 6     | 6       | 0       | 100%  |
| TOTAL                         | 86    | 85      | 1       | 98.8% |

Tableau 1 : Synthese des resultats de tests QA

Le taux de reussite global est de 98.8%, ce qui est excellent pour une application en phase de developpement. Le seul point d'attention concerne les headers de securite HTTP absents en mode developpement (normal en environnement de dev), et l'exposition du header X-Powered-By qui revele la stack technologique. Aucun bug critique bloque les fonctionnalites core de l'application. L'authentification, la sauvegarde des quiz, le module veille IA et la protection des routes fonctionnent tous conformement aux specifications.

## 2. Tests Frontend - Pages publiques

Chaque page publique a ete testee pour le code HTTP, la validite du HTML, la presence du titre CiviquePro, le branding coherent, et l'absence d'erreurs de rendu. Toutes les pages retournent un HTTP 200 avec un contenu HTML complet et structure, incluant la meta description, les liens de navigation et le footer.

| Page                       | HTTP | Taille (B) | HTML | Statut |
|----------------------------|------|------------|------|--------|
| Accueil /                  | 200  | 85 478     | Oui  | OK     |
| Login /login               | 200  | 69 803     | Oui  | OK     |
| Register /register         | 200  | 73 021     | Oui  | OK     |
| QCM /qcm                   | 200  | 106 923    | Oui  | OK     |
| Cours /cours               | 200  | 75 866     | Oui  | OK     |
| Annales /Annales           | 200  | 61 608     | Oui  | OK     |
| Questions /questions       | 200  | 143 683    | Oui  | OK     |
| Ressources /ressources     | 200  | 64 374     | Oui  | OK     |
| Examen Blanc /examen-blanc | 200  | 61 984     | Oui  | OK     |

Tableau 2 : Resultats des tests des pages publiques

### Analyse detaillee de la page d'accueil

| Element verifie                             | Resultat |
|---------------------------------------------|----------|
| Element                                     | Present  |
| Branding CiviquePro                         | Oui      |
| Navbar (COURS, QCM, EXAMEN)                 | Oui      |
| Lien /login                                 | Oui      |
| Lien /qcm                                   | Oui      |
| Lien /examen-blanc                          | Oui      |
| Lien /cours                                 | Oui      |
| CTA "Demarrer un QCM"                       | Oui      |
| Stats (40 questions, 5 themes, 45 min, 80%) | Oui      |
| 5 categories thematiques                    | Oui      |

|                        |     |
|------------------------|-----|
| Section FAQ            | Oui |
| Footer avec liens      | Oui |
| Gradient violet/orange | Oui |

Tableau 3 : Verification du contenu de la page d'accueil

### 3. Tests Frontend - Pages thematiques et Quiz

Les 5 pages thematiques presentent les QCM par categorie conformement au programme officiel de l'examen civique 2026. Chaque page affiche les series disponibles avec le nombre de questions, le chronometrage et les corrections. Les 7 pages de quiz fonctionnelles permettent de repondre aux questions avec un composant interactif cote client.

| Page thematique                                             | HTTP | Questions    | Statut |
|-------------------------------------------------------------|------|--------------|--------|
| Principes et valeurs<br>/qcm/theme/principes-valeurs        | 200  | 11 questions | OK     |
| Droits et devoirs<br>/qcm/theme/droits-devoirs              | 200  | 11 questions | OK     |
| Histoire, geographie<br>/qcm/theme/histoire-geographie      | 200  | 8 questions  | OK     |
| Systeme institutionnel<br>/qcm/theme/systeme-institutionnel | 200  | 6 questions  | OK     |
| Vivre en societe /qcm/theme/vivre-societe                   | 200  | 4 questions  | OK     |

Tableau 4 : Resultats des pages thematiques

| Page Quiz         | HTTP | Taille (B) | Statut |
|-------------------|------|------------|--------|
| Quiz PV Serie 1   | 200  | 65 636     | OK     |
| Quiz PV Serie 2   | 200  | 65 977     | OK     |
| Quiz DD Serie 1   | 200  | 66 001     | OK     |
| Quiz HG Serie 1   | 200  | 65 481     | OK     |
| Quiz SI Serie 1   | 200  | 65 331     | OK     |
| Quiz VS Serie 1   | 200  | 64 935     | OK     |
| Examen Blanc Quiz | 200  | 67 533     | OK     |

Tableau 5 : Resultats des pages quiz

## 4. Tests Frontend - Pages protegees

Les pages protegees par le middleware Next.js ont ete testees avec et sans authentication. La page /profil s'affiche en mode non-auth mais presente le formulaire de connexion (comportement client-side). La page /veille est correctement protegee et redirige vers /login avec un HTTP 307 lorsque l'utilisateur n'est pas authentifie. Ce comportement est conforme aux attentes de securite.

| Page et contexte   | HTTP | Comportement          | Statut |
|--------------------|------|-----------------------|--------|
| /profil (non auth) | 200  | Affiche login form    | OK     |
| /profil (auth)     | 200  | Dashboard utilisateur | OK     |
| /veille (non auth) | 307  | Redirige vers /login  | OK     |
| /veille (auth)     | 200  | Dashboard veille IA   | OK     |

Tableau 6 : Resultats des pages protegees

## 5. Tests Backend API - Authentication

Le systeme d'authentification repose sur NextAuth.js v4 avec une strategie JWT, supportant les providers credentials, Google et Facebook (ces derniers desactives en dev). Le flux CSRF est fonctionnel, les sessions JWT sont correctement emises et les tokens d'authentification sont valides. L'inscription cree un nouvel utilisateur avec hashage bcrypt du mot de passe, et la connexion retourne un cookie de session signe.

| Endpoint / Test                          | HTTP | Reponse                      |
|------------------------------------------|------|------------------------------|
| GET /api/auth/providers-status           | 200  | google:false, facebook:false |
| POST /api/auth/register (compte nouveau) | 201  | Compte cree avec succes      |
| POST /api/auth/register (doublon email)  | 409  | Un compte existe deja        |
| POST /api/auth/register (champs vides)   | 400  | Tous les champs sont requis  |
| POST /api/auth/register (email invalide) | 400  | Adresse email invalide       |

|                                          |     |                                |
|------------------------------------------|-----|--------------------------------|
| POST /api/auth/register (password court) | 400 | 6 caracteres minimum           |
| GET /api/auth/csrf                       | 200 | Token CSRF genere              |
| POST /api/auth/callback/credentials      | 200 | Session JWT creee              |
| GET /api/auth/session (auth)             | 200 | User name + email + id         |
| GET /api/auth/session (no auth)          | 200 | Objet vide {}                  |
| POST login (mauvais password)            | 302 | Redirection (echec silencieux) |

Tableau 7 : Resultats des tests d'authentification

## 6. Tests Backend API - Quiz Results

L'API de quiz results permet la sauvegarde et la consultation des resultats des utilisateurs. Les endpoints sont correctement proteges par authentification : les requetes sans session valide retournent un HTTP 401. La sauvegarde d'un resultat de quiz cree un enregistrement complet avec le type de quiz, le theme, la serie, le score, le statut passe/echoue, le temps utilise et les reponses detaillees. Les statistiques agregees sont calculees par type et par theme avec le taux de reussite.

| Endpoint / Test                        | HTTP | Reponse             |
|----------------------------------------|------|---------------------|
| GET /api/quiz-results (no auth)        | 401  | Non autorise        |
| GET /api/quiz-results (auth)           | 200  | Liste des resultats |
| POST /api/quiz-results (save)          | 201  | Resultat sauvegarde |
| POST /api/quiz-results (data invalide) | 400  | Donnees manquantes  |
| GET /api/quiz-results/stats (auth)     | 200  | Stats agregees      |
| GET /api/quiz-results/stats (no auth)  | 401  | Non autorise        |

Tableau 8 : Resultats des tests Quiz Results

## 7. Tests Backend API - Module Veille IA

Le module Veille IA est le coeur de la fonctionnalite de monitoring de CiviquePro. Il integre le SDK z-ai-web-dev-sdk pour effectuer des recherches web automatisees sur les changements legislatifs et gouvernementaux francais, analyser les resultats avec

l'IA, et generer des suggestions de questions pour l'examen civique. L'audit a verifie 7 endpoints avec et sans authentication, testant egalement les parametres requis et les reponses aux cas limites.

| Endpoint / Test                              | HTTP | Reponse                               |
|----------------------------------------------|------|---------------------------------------|
| GET /api/veille/status (auth)                | 200  | Dashboard: 24 updates, 5 gov members  |
| GET /api/veille/status (no auth)             | 401  | Protege                               |
| GET /api/veille/government (auth)            | 200  | 5 membres du gouvernement             |
| GET /api/veille/government (no auth)         | 401  | Protege                               |
| POST /api/veille/search (auth)               | 200  | 7 changements detectes, 7 suggestions |
| POST /api/veille/search (no auth)            | 401  | Protege                               |
| POST /api/veille/analyze (auth, bons params) | 200  | Questions generees par IA             |
| POST /api/veille/analyze (params manquants)  | 400  | legalUpdateId et themeId requis       |
| POST /api/veille/analyze (no auth)           | 401  | Protege                               |
| GET /api/veille/digest (auth)                | 200  | Resume hebdomadaire: 12 updates       |
| GET /api/veille/digest (no auth)             | 401  | Protege                               |
| POST /api/veille/apply (id inexistant)       | 404  | Suggestion non trouvee                |
| POST /api/veille/apply (no auth)             | 401  | Protege                               |
| GET /api/veille/cron (no auth)               | 401  | Authentication requise                |

Tableau 9 : Resultats des tests Module Veille IA

## 8. Tests Backend API - Gestion utilisateur

Les endpoints de gestion du profil utilisateur permettent la modification du nom d'affichage et du mot de passe. Ces endpoints utilisent la methode POST (et non PUT), ce qui est un choix de conception valide. La validation des entrees est robuste : le nom ne peut pas etre vide, le mot de passe actuel doit etre verifie avant changement, et le nouveau mot de passe doit contenir au minimum 8 caracteres. Les utilisateurs avec connexion sociale (OAuth) ne peuvent pas changer leur mot de passe, ce qui est un comportement de securite correct.

| Endpoint / Test                                 | HTTP | Reponse                       |
|-------------------------------------------------|------|-------------------------------|
| POST /api/user/update-name (auth)               | 200  | Nom mis a jour                |
| POST /api/user/update-name (no auth)            | 401  | Protege                       |
| POST /api/user/update-name (nom vide)           | 400  | Le nom est requis             |
| POST /api/user/update-password (auth)           | 200  | Mot de passe change           |
| POST /api/user/update-password (no auth)        | 401  | Protege                       |
| POST /api/user/update-password (mauvais ancien) | 400  | Mot de passe actuel incorrect |
| POST /api/user/update-password (nouveau < 8)    | 400  | 8 caracteres minimum          |

Tableau 10 : Resultats des tests Gestion utilisateur

## 9. Securite et protection des routes

La securite de l'application a ete testee de maniere exhaustive. Le middleware Next.js protege correctement les 14 routes API sensibles (veille, quiz-results, user) en retournant un HTTP 401 pour les requetes non authentifiees. La page /veille est protegee par redirection 307 vers /login. Les validations d'entrees sont robustes : les champs vides, les emails invalides, les mots de passe trop courts et les doublons d'inscription sont tous correctement rejetes avec des messages d'erreur explicites.

| Test de securite                          | HTTP | Comportement        |
|-------------------------------------------|------|---------------------|
| GET /api/veille/* (7 endpoints, no auth)  | 401  | Tous proteges       |
| POST /api/veille/* (3 endpoints, no auth) | 401  | Tous proteges       |
| GET /api/quiz-results (no auth)           | 401  | Protege             |
| GET /api/quiz-results/stats (no auth)     | 401  | Protege             |
| POST /api/user/update-name (no auth)      | 401  | Protege             |
| POST /api/user/update-password (no auth)  | 401  | Protege             |
| Inscription doublon email                 | 409  | Rejete correctement |
| Inscription champs vides                  | 400  | Rejete correctement |



|                                     |     |                     |
|-------------------------------------|-----|---------------------|
| Inscription email invalide          | 400 | Rejete correctement |
| Password trop court a l'inscription | 400 | Rejete correctement |
| Password trop court au changement   | 400 | Rejete correctement |
| Mauvais mot de passe actuel         | 400 | Rejete correctement |
| Quiz data invalide                  | 400 | Rejete correctement |
| Page 404 personnalisee              | 404 | Page non trouvee    |

Tableau 11 : Resultats des tests de securite

## 10. Performance et SEO

Les performances de l'application sont excellentes avec des temps de reponse inferieurs a 100ms pour toutes les pages en mode developpement (compilation Turbopack incluse). Le SEO est bien configure avec les balises meta essentielles (description, keywords, viewport, charset). L'accessibilite est prise en compte avec des attributs aria-label sur les elements interactifs et une structure HTML semantique (header, main, section). Le design responsive utilise Tailwind CSS avec des breakpoints sm/md/lg pour une adaptation mobile correcte.

| Page                       | Temps de reponse |
|----------------------------|------------------|
| Accueil /                  | 39 ms            |
| Login /login               | 80 ms            |
| Register /register         | 65 ms            |
| QCM /qcm                   | 48 ms            |
| Cours /cours               | 36 ms            |
| Annales /annales           | 28 ms            |
| Questions /questions       | 41 ms            |
| Ressources /ressources     | 30 ms            |
| Examen Blanc /examen-blanc | 30 ms            |

Tableau 12 : Temps de reponse des pages (mode dev, Turbopack)

### Verification SEO et accessibilite

| Element                      | Statut  |
|------------------------------|---------|
| Lang=fr                      | OK      |
| Meta description             | OK      |
| Meta keywords                | OK      |
| Viewport meta                | OK      |
| UTF-8 charset                | OK      |
| Aria labels                  | OK      |
| Design responsive (sm/md/lg) | OK      |
| X-Content-Type-Options       | Absent  |
| X-Frame-Options              | Absent  |
| X-Powered-By expose          | Present |

Tableau 13 : Verification SEO et securite HTTP

## 11. Base de donnees

La base de donnees SQLite gere par Prisma ORM contient les donnees coherentes attendues. Les 7 modeles Prisma (User, Account, Session, QuizResult, LegalUpdate, QuestionSuggestion, GovernmentMember, VeilleLog) sont tous fonctionnels. Les relations entre les tables sont correctes : les QuizResult sont lies aux utilisateurs, les QuestionSuggestions sont liees aux LegalUpdate, et les VeilleLog enregistrent l'historique des operations IA. L'integrite referentielle est respectee et les requetes Prisma fonctionnent sans erreur.

| Table              | Enregistrements | Description                                      |
|--------------------|-----------------|--------------------------------------------------|
| User               | 11              | Utilisateurs inscrits dont tests QA              |
| QuizResult         | 2               | Resultats de quiz sauvegardes                    |
| LegalUpdate        | 24              | Changements juridiques detectes par la veille IA |
| GovernmentMember   | 5               | Membres du gouvernement Lecornu II               |
| QuestionSuggestion | 27              | Suggestions generees par l'IA                    |
| VeilleLog          | 6               | Logs des operations de veille                    |

## 12. Bugs et anomalies detectees

L'audit a identifie un nombre limite d'anomalies, principalement liees a la configuration de securite en environnement de developpement. Aucun bug critique ne bloque les fonctionnalites principales. Les anomalies sont classees par severite selon l'echelle standard QA : Critique (bloquant), Majeur (fonctionnalite degradee), Mineur (cosmetique/UX), et Info (amelioration suggeree).

| ID | Description                                                                | Severite | Action corrective                                  |
|----|----------------------------------------------------------------------------|----------|----------------------------------------------------|
| B1 | Headers de securite absents (X-Content-Type-Options, X-Frame-Options, CSP) | Majeur   | Ajouter les headers dans next.config.ts            |
| B2 | X-Powered-By expose la stack Next.js                                       | Mineur   | Desactiver via poweredHeader: false                |
| B3 | middleware.ts deprtie en Next.js 16 (utiliser proxy)                       | Info     | Migrer vers la convention proxy                    |
| B4 | Page /profil sans bouton deconnexion visible en SSR                        | Info     | Rendu client-side normal, a verifier en navigateur |
| B5 | output: standalone non configure pour la production                        | Info     | Configurer pour le deploiement Docker              |

Tableau 15 : Liste des anomalies detectees

## 13. Recommandations et plan d'action

Sur la base des resultats de cet audit, les recommandations suivantes sont classees par priorite. Les actions a haute priorite doivent etre implementees avant tout deploiement en production. Les actions a priorite moyenne concernent les ameliorations de qualite et de securite. Les actions a basse priorite sont des optimisations et des ameliorations d'experience utilisateur.

### Priorite haute (avant production)

1. **Securiser les headers HTTP** : Configurer les headers X-Content-Type-Options, X-Frame-Options, Content-Security-Policy et Strict-Transport-Security dans le fichier

next.config.ts ou via un middleware de securite dedie. Cela empeche les attaques de type clickjacking, MIME sniffing et injection de contenu.

2. **Desactiver X-Powered-By** : Ajouter poweredHeader: false dans next.config.ts pour ne pas exposer la stack technologique aux attaquants potentiels.

3. **Configurer NEXTAUTH\_SECRET en production** : Le secret actuel est un placeholder de developpement. Generer un secret cryptographiquement securise pour la production (min 32 caracteres aleatoires).

## **Priorite moyenne (ameliorations qualite)**

4. **Migrer middleware.ts vers proxy** : Next.js 16 deprecie le fichier middleware.ts au profit de la convention proxy. Planifier la migration pour rester conforme aux evolutions du framework.

5. **Configurer output: standalone** : Pour le deploiement en production via Docker, activer le mode standalone dans next.config.ts afin de reduire la taille de l'image et optimiser les performances.

6. **Creer un utilisateur demo fiable** : Les utilisateurs existants en base ont des mots de passe inconnus. Creer un utilisateur demo avec des identifiants documentes pour les demonstrations et les tests.

## **Priorite basse (optimisations)**

7. **Ameliorer la veille IA** : Connecter le module veille a des sources de donnees reelles (RSS Légifrance, API service-public.fr) pour une surveillance proactive des changements legislatifs et gouvernementaux.

8. **Ajouter des tests automatises** : Implementer une suite de tests E2E avec Playwright ou Cypress pour automatiser la regression et garantir la qualite des futures releases.

9. **Monitoring en production** : Integrer un systeme de monitoring (Sentry, Datadog) pour detecter les erreurs en temps reel et assurer la disponibilite du service.